

Clase 182 — Logging y fuentes de telemetría

Parte: **8 — Blue Team, detección y SOC** · Fuente: *Applied Network Security Monitoring* — Chris Sanders y Jason Smith · *NIST SP 800-92* 🕒 Duración estimada: **100 min** · Nivel: **Fundamentos**

🎯 Objetivo

Aprender qué telemetría existe, cómo se clasifica y cómo diseñar una estrategia de recolección que no deje puntos ciegos críticos. Sin buenos datos, la mejor detección es inútil: esta clase construye la base de "materia prima" que alimentará el SIEM, el hunting y toda la detección posterior.

📖 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Clasificar** fuentes de telemetría (host, red, identidad, nube, aplicación).
2. **Distinguir** datos de sesión, transacción, alerta, estadística y contenido completo (taxonomía NSM).
3. **Priorizar** qué registrar según valor de detección y coste de almacenamiento.
4. **Configurar** reenvío de logs con agentes y syslog hacia un colector central.
5. **Detectar** puntos ciegos en la cobertura de logging de una red.

📖 Temas

#	Tema	Por qué importa
1	Taxonomía de datos NSM	Da un vocabulario para pensar la telemetría
2	Fuentes de endpoint (Event Logs, Sysmon, EDR)	Donde ocurre la ejecución del ataque
3	Fuentes de red (flujo, PCAP, DNS, proxy)	Ven lo que el host puede ocultar
4	Identidad y autenticación (AD, IdP, VPN)	La identidad es el nuevo perímetro
5	Nube y SaaS (CloudTrail, M365 audit)	El log del data center ya no basta
6	Normalización y marcas de tiempo (UTC, NTP)	Sin tiempo correcto no hay correlación
7	Retención y coste	Equilibra visibilidad y presupuesto
8	Puntos ciegos y cobertura	Un atacante prospera donde no hay logs

📖 Definiciones y características

- **Datos de sesión (flow):** metadatos de conexiones (IP origen/destino, puertos, bytes, duración). Característica: baratos y de larga retención; ideales para hunting histórico.
- **Contenido completo (full packet capture):** PCAP con la carga útil. Característica: máxima fidelidad, alto coste de almacenamiento; se retiene poco tiempo.

- **Datos de alerta:** salidas de IDS/EDR (Suricata, Snort). Característica: ya interpretados, propensos a falsos positivos.
- **Datos estadísticos:** agregados (top talkers, volúmenes). Característica: útiles para anomalías y línea base.
- **Log de endpoint:** eventos del SO y aplicaciones (Security.evtx, Sysmon). Característica: granularidad de proceso, línea de comandos, red por proceso.
- **Normalización:** llevar campos heterogéneos a un esquema común (ej. ECS de Elastic). Característica: habilita correlación entre fuentes.
- **Sincronización NTP:** todos los relojes en la misma referencia (UTC). Característica: sin ella, las líneas de tiempo son inservibles.

Herramientas y preparación

Monta un laboratorio aislado con:

- **Sysmon** (Sysinternals) en un Windows de pruebas, con una configuración base (p. ej. la de SwiftOnSecurity como punto de partida).
- **Winlogbeat** o **NXLog** para reenviar Event Logs.
- **rsyslog/syslog-ng** en un Linux como colector central.
- **Zeek** (antes Bro) para telemetría de red rica (conn.log, dns.log, http.log).
- Un servidor NTP interno o `chrony` / `w32tm` apuntando a una fuente confiable.

Todo en tu red de laboratorio; no captures tráfico de redes que no te pertenecen.

Laboratorio guiado — Centraliza y cubre puntos ciegos

1. **Instala Sysmon** en el Windows de laboratorio: `sysmon64.exe -accepteula -i sysmonconfig.xml`. Verifica en Visor de eventos: *Applications and Services Logs > Microsoft > Windows > Sysmon/Operational*.
2. **Reenvía Event Logs.** Configura Winlogbeat (`winlogbeat.yml`) para enviar los canales Security y Sysmon/Operational hacia tu colector.
3. **Levanta el colector.** En Linux, habilita recepción syslog en rsyslog (`module(load="imudp")` y `input(type="imudp" port="514")`).
4. **Añade telemetría de red.** Instala Zeek en un tap/mirador del laboratorio: `zeek -i eth0 local` . Revisa `conn.log` y `dns.log` .
5. **Sincroniza el tiempo.** Configura NTP en todas las máquinas y confirma con `w32tm /query /status` (Windows) y `chronyc tracking` (Linux). Todo en UTC.
6. **Mapa de cobertura.** Crea una tabla activo × fuente de log y marca huecos: ¿registras autenticación? ¿DNS? ¿PowerShell? ¿tráfico saliente?
7. **Prueba de humo.** Ejecuta un comando benigno (`whoami /all`) y confirma que aparece en el colector con timestamp coherente entre host y red.

Ejercicios

1. Clasifica 8 fuentes de tu laboratorio según la taxonomía NSM.
2. Calcula el coste aproximado de retener 30 días de PCAP para un enlace de 100 Mbps al 20% de uso.
3. Diseña una política de retención por tipo de dato (flow, alerta, endpoint, PCAP).
4. Identifica 3 puntos ciegos típicos en una pyme y cómo cerrarlos.

5. Explica por qué el log de PowerShell (ScriptBlock) merece prioridad alta.
6. Propón qué recolectar de M365/Azure AD y por qué.

Reto verificable

Entrega un **plan de logging** de una página con: matriz activo×fuente, prioridad (alta/media/baja) por fuente, política de retención y 3 puntos ciegos con su remediación. **Criterio de aceptación:** en tu laboratorio, un evento generado en el endpoint aparece en el colector central con la misma marca de tiempo (± 2 s) que la vista local, demostrando reenvío y sincronización correctos.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Eventos con horas descuadradas	NTP no configurado; sincroniza todo a UTC
El SIEM no recibe Sysmon	Canal no incluido en Winlogbeat; añade <code>Microsoft-Windows-Sysmon/Operational</code>
Volumen de logs dispara el coste	Registras todo sin filtrar; filtra ruido (ej. eventos 4688 irrelevantes)
No hay rastro de un ataque conocido	Punto ciego; faltaba PowerShell/DNS logging
Campos incomparables entre fuentes	Sin normalización; adopta un esquema común (ECS)

Preguntas frecuentes

 **¿Registro todo o filtro?** Filtra con criterio. Registrar todo agota presupuesto y entierra las señales. Prioriza por valor de detección (ver pirámide del dolor en la clase 187).

 **¿Event Logs nativos o Sysmon?** Ambos. Los nativos dan autenticación y auditoría; Sysmon aporta creación de procesos con hash, línea de comandos y conexiones por proceso.

 **¿Necesito PCAP completo?** Solo en segmentos críticos y con retención corta. Para hunting histórico, los datos de sesión (flow/Zeek) rinden mucho más por byte almacenado.

Referencias

- Sanders, C. y Smith, J. *Applied Network Security Monitoring*. Syngress.
- NIST SP 800-92, *Guide to Computer Security Log Management* — <https://csrc.nist.gov/publications/detail/sp/800-92/final>
- Microsoft Sysmon — <https://learn.microsoft.com/sysinternals/downloads/sysmon>
- Zeek Documentation — <https://docs.zeek.org/>
- Elastic Common Schema (ECS) — <https://www.elastic.co/guide/en/ecs/current/index.html>

Siguiente clase

Clase 183 - SIEM: arquitectura y componentes